

Autodesk App Store Readiness Report

Forma User Management Application

Prepared by: Digibuild

Report Date: 16 September 2026

Application Version: v2.1.0

Target Category: BIM 360 / ACC Integration

12/12

CODE REQUIREMENTS
COMPLETE

3

BUSINESS TASKS
REMAINING

2

DRAFTS AWAITING LEGAL
REVIEW

Bottom line: every requirement that required a code change has been implemented, tested, and deployed to production. What remains is entirely business/ administrative work — publisher registration, submission assets, and a legal review of the drafted Terms of Service and Privacy Policy — none of which requires further engineering.

1. Architecture Decisions

APS App Type: Traditional Web App

- 3-legged OAuth (Authorization Code)
- Confirmed against Autodesk's own BIM 360 publisher documentation — no server-to-server mandate exists for this category of app

One Publisher-Owned APS App (Model B)

- A single Client ID/Secret, owned by Digibuild, used for every customer
- Customers never create their own APS app or see a Client ID/Secret

- Validated against a live, approved comparable listing (Enlaye for Autodesk Forma), which uses the identical flow

- Replaces the previous per-tenant "bring your own credentials" flow

Existing Login System Retained

- digibuild.ch (Firebase) accounts stay as the primary login
- No change to how licenses are tied to an account
- A larger move to Autodesk-only sign-in was considered and parked — not required for this submission

Listed as Free

- The store listing is a credibility signal, not the sales channel
- Real subscriptions continue through the existing PayPal flow on Digibuild's own site
- Avoids routing revenue through Autodesk's store checkout and commission terms

2. Code Compliance Checklist

Requirement	Resolution
✓ Single publisher-owned APS app	Per-tenant credential flow removed entirely; shared Client ID/Secret in server environment variables; registered, deployed, and confirmed working end-to-end
✓ Autodesk OAuth branding	Sign-in button shows Autodesk's real, unmodified logo + "Sign in," sourced directly from Autodesk's own asset CDN. Login page carries the official Autodesk Forma product lockup as a compatibility badge
✓ OAuth scope minimisation	Every API call in the codebase audited against Autodesk's own reference documentation; one genuinely unused scope (<code>data:create</code>) removed, everything else confirmed in active use
✓ Token handling / session UX	<code>offline_access</code> requested; refresh tokens stored encrypted (AES-256-GCM) server-side and never exposed to the browser; access tokens silently renewed ~5 minutes before expiry during an active session
✓ Region routing (EMEA / US)	Verified directly against Autodesk's dated documentation that this app's entire API surface is either unaffected or auto-routed server-side by Autodesk — no code change required
✓ Documented APIs only	One code comment reworded to describe a documented endpoint on its own terms, removing language that read as a reverse-engineering methodology
✓ No incompleteness / beta signals	Stale "coming soon" documentation corrected; a UI authentication bypass (<code>?demo=true</code>) removed entirely; confirmed no "beta" wording anywhere in the product
✓ Automatic licensing / entitlement	Traced end-to-end and confirmed already compliant: license keys are issued instantly on purchase and auto-applied on registration or next login; trials start automatically; confirmed with a real test purchase
✓ EULA acceptance	Terms of Service drafted; a first-login acceptance gate blocks use until a customer explicitly agrees, recorded server-side
✓ Privacy policy	Drafted covering data collected, third parties, retention, deletion rights, and token handling; linked from the app and the acceptance gate
✓ APS Client ID display	The in-app "Custom Integration" helper displays the live Client ID paired with the app name, for a customer's hub admin to authorize the connection

Requirement	Resolution
✓ No public data exposure	Audit found and fixed a real gap — one admin action wrote to the database directly from the browser instead of through an authenticated server endpoint; fixed and, in the process, removed all remaining client-side database access from the entire application

3. Key Verified Findings

Several items were resolved by direct verification against Autodesk's own current documentation or the app's actual code, rather than by writing new code — worth recording since they overturn earlier assumptions:

Region routing was already solved by Autodesk, not by this app

Autodesk's own documentation (dated March 2024) confirms automatic region routing for every API this app calls; only the Model Derivative API and pre-2021 Viewer versions ever needed manual handling, and this app uses neither.

Licensing was already automatic

Tracing the actual purchase-to-activation code path showed license keys are shown on-screen immediately and pre-filled into the registration link — not the "email me a key" pattern Autodesk rejects. Confirmed with a real test purchase.

A real access-control gap was found and closed

One admin action wrote directly to the database from the browser, relying on database rules configured outside this codebase rather than the server's own authentication middleware. Fixed by routing it through a new authenticated endpoint, matching every other admin action in the app.

Scope over-requesting was minimal, not extensive

A full audit of every Autodesk API call in the codebase found exactly one unused scope, not the several originally assumed — the rest are all genuinely exercised by real functionality (folder permissions, user/company management).

4. Remaining Tasks — Business / Non-Code

Task	Status	Notes
Verify APS app portal settings	PENDING	Confirm the callback URL list contains only the production domain, and that API Access is scoped to only the APIs actually used
Publisher registration	PENDING	Register at apps.autodesk.com; accept the Publisher Agreement; provide a support contact
Submission assets	PENDING	App icon, up to 10 screenshots, description text, and the compatibility/login type selections on the submission form

Open question for Autodesk: the original meeting notes that informed this review referenced a "server-to-server" requirement for Forma extension types. Current evidence (the official BIM 360 publisher page, and a live comparable listing) strongly supports Traditional Web App being correct for this application, but the exact source of that note has not been confirmed directly with Autodesk. Worth a direct question before it becomes costly to reverse.

5. Legal Documents

Drafted, not yet legally reviewed: Terms of Service and Privacy Policy have been written to accurately describe this application's actual technical and commercial practices (data collected, retention, third parties, token handling, trial and billing terms), and are live in the application with a first-login acceptance gate. They are a solid first draft, not a substitute for review by a qualified legal professional — particularly the liability and governing-law clauses — before being treated as final.

6. Full Requirement Summary

Requirement	Status
✓ APS app registered (Traditional Web App, 3-legged)	DONE
✓ Per-tenant credential flow retired	DONE
✓ Autodesk OAuth branding	DONE

Requirement	Status
✓ OAuth scope minimisation	DONE
✓ Token handling / silent refresh	DONE
✓ Region routing verified	DONE
✓ Documented APIs only	DONE
✓ No incompleteness / beta signals	DONE
✓ Automatic licensing / entitlement	DONE
✓ EULA acceptance gate	DONE
✓ Privacy policy	DONE
✓ APS Client ID display	DONE
✓ No public data exposure	DONE
ⓘ APS portal settings self-check	PENDING
ⓘ Publisher registration	PENDING
ⓘ Submission assets	PENDING
ⓘ Legal review of Terms/Privacy drafts	PENDING

Prepared by — Digibuild

Reviewed by